

WEEK 9 INVESTIGATION

Cerber Ransomware Infection via RIG Exploit Kit

Team Members: Jay-Byrd Mystic | Date: 03/29/2026 | Course: Network Forensics

Abstract

Investigation overview and key findings

This investigation analysed a PCAP file captured on **2017-01-27** containing network traffic from internal host **172.16.4.193 (STEWIE-PC)**, a Windows 7 machine on the 172.16.4.0/24 network.

STEWIE-PC was infected with **Cerber ransomware** following a drive-by download attack. The infection chain began at a compromised WordPress site (www.homeimprovement.com), proceeded through an evil redirector, and delivered the **RIG exploit kit** via C2 server tyu.benme.com (194.87.234.129). Flash exploits and Windows executables were dropped. The ransomware loaded a payment portal and displayed a Bitcoin ransom demand. The full attack was captured in **under 7 minutes**.

Introduction

Background, objective, scope, and toolset

Objective

- Identify the malware type and infection vector
- Map the full attack chain from initial access to ransomware
- Extract all indicators of compromise (IOCs)
- Assess accuracy of IDS detection vs false positives

Tools Used

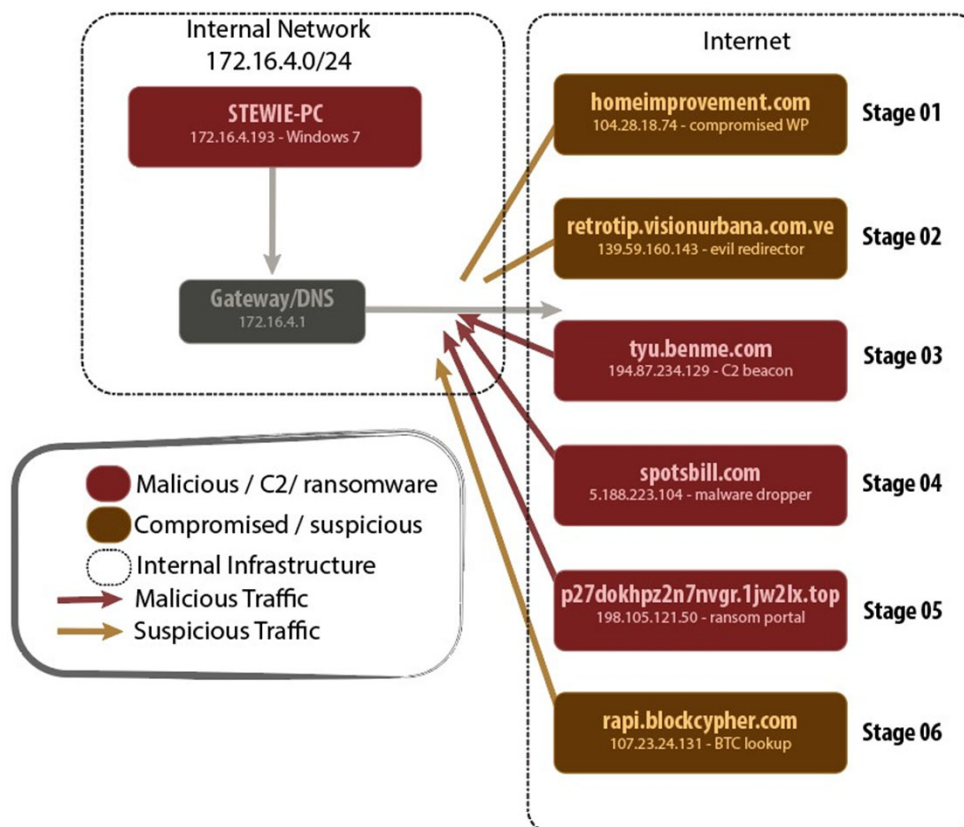
- Security Onion (Suricata IDS alerts)
- Wireshark / PCAP analysis
- NetworkMiner (host/file enumeration)
- VirusTotal (IOC validation)

Scope

- Single infected host: 172.16.4.193
- Timeframe: 22:53–22:59 UTC Jan 27 2017
- 6,033 packets — 403 second capture
- No lateral movement observed

The Network

Internal topology and external connections identified from PCAP



Methodology

Analytical process used to reconstruct the attack

1 Alert Triage

Reviewed Security Onion Alerts dashboard. Grouped alerts by source IP and rule name. Identified highest-severity Suricata signatures as starting point.

2 OSINT Validation

Queried each IOC (IPs and domains) in VirusTotal. Obtained independent vendor verdicts and community intelligence to confirm or rule out false positives.

3 PCAP Analysis

Applied Wireshark display filters per malicious IP. Followed HTTP streams to reconstruct payloads. Used Export Objects to identify downloaded files.

4 Host Enumeration

Loaded PCAP into NetworkMiner to identify hostnames, OS fingerprints, MAC addresses, and all outgoing sessions from the infected host.

5 IOC Extraction

Extracted all IP addresses, domains, Bitcoin addresses, victim GUIDs, file hashes, and MITRE ATT&CK mappings from correlated evidence.

6 Timeline Construction

Cross-referenced all timestamps, IPs, and hostnames to build a chronological attack timeline from initial access to ransomware payment portal.

Timeline of Events

All times UTC — 2017-01-27

Time (UTC)	Stage	Source	Destination	Description
22:53:08	Capture begins	172.16.4.193	—	Normal browsing — Bing, Microsoft login, NCSI check
22:54:41	① Initial infection	172.16.4.193	104.28.18.74	User visits compromised www.homeimprovement.com (WordPress)
22:54:42	② Evil redirector	139.59.160.143	172.16.4.193	Malicious JS (dle_js.js) delivered — RIG EK redirector fires
22:54:43	③ C2 beacon	172.16.4.193	194.87.234.129	Malware beacons to tyu.benme.com — browser fingerprint exfiltrated
22:55:06	③ Payload delivery	194.87.234.129	172.16.4.193	Flash exploits (16kB) and .exe files (165kB, 500kB) downloaded
22:55:12	④ Dropper contact	172.16.4.193	5.188.223.104	GET /find.php to spotsbill.com — secondary malware dropper
22:55:27	⑤ Ransom DNS	172.16.4.193	172.16.4.1	DNS query for p27dokhpz2n7nvgr.1jw2lx.top — Cerber confirmed
22:55:28	⑤ Ransom portal	172.16.4.193	198.105.121.50	Ransomware payment page loaded — GUID EE7E-AD39-7D8C-080C-18BF
22:55:27	⑤ BTC lookup	172.16.4.193	107.23.24.131	Bitcoin address 17gd1msp5FnMcEMF1MitTNSsYs7w7AQyCt queried
22:56:38	⑤ CAPTCHA solved	172.16.4.193	198.105.121.50	POST /captcha/click — victim interacts with payment portal

Indicators of Compromise (IOCs)

All IOCs extracted from PCAP and validated via VirusTotal

Type	Value	Description	Verdict
IP Address	172.16.4.193	Infected host — STEWIE-PC	Internal
IP Address	194.87.234.129	C2 beacon — tyu.benme.com	Malicious
IP Address	198.105.121.50	Ransomware payment portal	Malicious
IP Address	5.188.223.104	Malware dropper — spotsbill.com	11/94 VT
IP Address	139.59.160.143	Evil redirector — visionurbana	2/98 VT
Domain	p27dokhpz2n7nvgr.1jw2lx.top	Cerber ransomware payment portal	4/94 VT
Domain	spotsbill.com	Malware dropper infrastructure	11/94 VT
Domain	tyu.benme.com	RIG EK C2 server	Malicious
Bitcoin Addr	17gd1msp5FnMcEMF1MitTNSsYs7w7AQyCt	Cerber ransom payment wallet	Ransom
GUID	EE7E-AD39-7D8C-080C-18BF	Victim unique identifier assigned by Cerber	Ransomware ID
Malware	Cerber Ransomware / RIG Exploit Kit	Confirmed by Suricata + MITRE T1486	Confirmed
MITRE ATT&CK	T1486 — Data Encrypted for Impact	TA0040 Impact — file encryption for ransom	Confirmed

Security Onion alerts confirming the attack chain

Figure 1: Suricata alert list showing RIG EK (x15), Evil Redirector, Cerber Ransomware, and .top domain alerts — all High severity

Figure 2: Cerber alert metadata — confirms malware_family: Ransomware Cerber, MITRE T1486

Evidence — RIG Exploit Kit Delivery

Stages 1–3: evil redirector → EK landing → payload drop



Fig 3: Evil Redirector delivering dle.js.js (text/javascript)

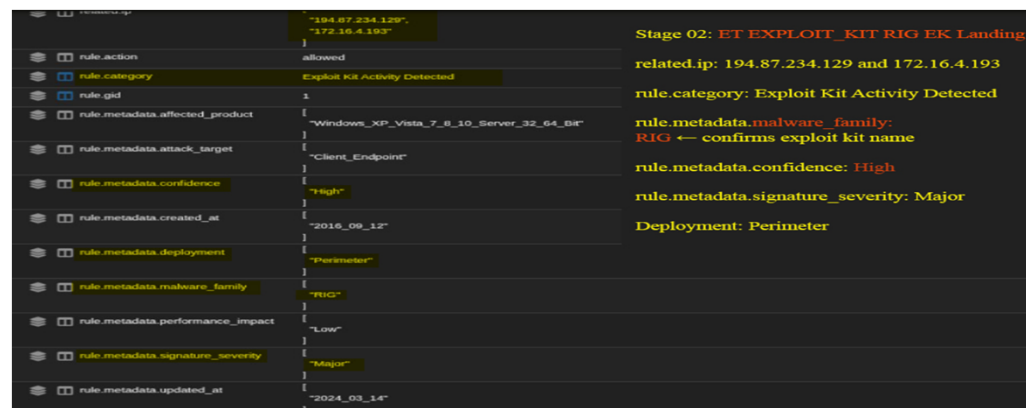


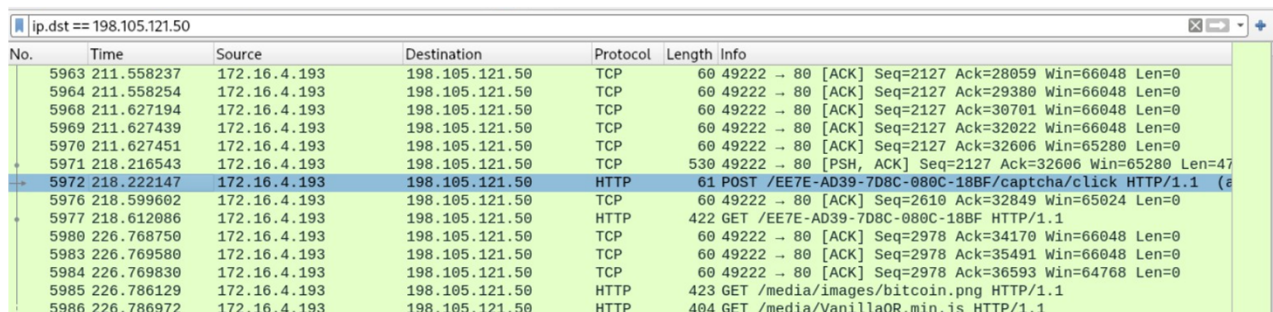
Fig 4: RIG EK Landing metadata — malware_family: RIG, severity: Major

Packet	Hostname	Content Type	Size	Filename
3422	tyu.benme.com	application/x-msdownload	165kB	?yus=SeaMonkey.115uv80.406n4b3l1&br_fl=2106&tuif=5015&ct=SeaMonkey&oq=X_fUIL7
3969	tyu.benme.com	application/x-msdownload	500kB	?ct=Mozilla&tuif=3379&q=wXbQMvXcJwDQC4bGMvrESLtgNknQA0KK2Iz2_dqyEoH9fWni
5876	tyu.benme.com	application/x-msdownload	165kB	?br_fl=5844&tuif=5862&ct=Mozilla&q=w3nQMvXcJx7QFYbGMvrDSKNbNkjWHViPxo-G9M
3155	tyu.benme.com	application/x-shockwave-flash	16kB	?biw=SeaMonkey.105qj67.406x7d8b3&yus=SeaMonkey.78vg115.406g6d1r6&br_fl=2957&c
3165	tyu.benme.com	application/x-shockwave-flash	16kB	?biw=Amaya.126qv100.406m1g9g5&ct=Amaya&tuif=2927&q=zn3QMvXcJwDQDoTGMvrE
5595	tyu.benme.com	application/x-shockwave-flash	16kB	?tuif=2138&br_fl=1788&oq=_skK7pSP1LghRbVcgU3n4lbWw8S_6qniBCBmBWUgcSHrxLeN
5938	p27dokhnp2n7nvgr.1jw2lx.top	application/x-www-form-urlencoded	6 bytes	click
5972	p27dokhnp2n7nvgr.1jw2lx.top	application/x-www-form-urlencoded	7 bytes	click
230	www.bing.com	application/x-www-form-urlencoded	4 bytes	ncheader?ver=8_1_2_6162224&IID=SERP.5060&IG=194EC908DA65455B9E9A98285A3313

Fig 5: Wireshark HTTP Export Objects — malicious executables and Flash exploits downloaded from 194.87.234.129 (tyu.benme.com)

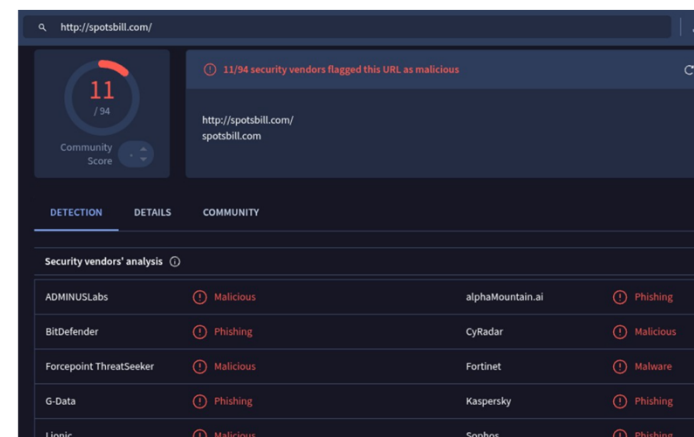
Evidence — Ransomware Payment Portal

Stage 5: Cerber payment portal, victim GUID, Bitcoin wallet



No.	Time	Source	Destination	Protocol	Length	Info
5963	211.558237	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2127 Ack=28059 Win=66048 Len=0
5964	211.558254	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2127 Ack=29380 Win=66048 Len=0
5968	211.627194	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2127 Ack=30701 Win=66048 Len=0
5969	211.627439	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2127 Ack=32022 Win=66048 Len=0
5970	211.627451	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2127 Ack=32606 Win=65280 Len=0
5971	218.216543	172.16.4.193	198.105.121.50	TCP	530	49222 → 80 [PSH, ACK] Seq=2127 Ack=32606 Win=65280 Len=47
5972	218.222147	172.16.4.193	198.105.121.50	HTTP	61	POST /EE7E-AD39-7D8C-080C-18BF/captcha/click HTTP/1.1 (e
5976	218.599602	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2610 Ack=32849 Win=65024 Len=0
5977	218.612086	172.16.4.193	198.105.121.50	HTTP	422	GET /EE7E-AD39-7D8C-080C-18BF HTTP/1.1
5980	226.768750	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2978 Ack=34170 Win=66048 Len=0
5983	226.769580	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2978 Ack=35491 Win=66048 Len=0
5984	226.769830	172.16.4.193	198.105.121.50	TCP	60	49222 → 80 [ACK] Seq=2978 Ack=36593 Win=64768 Len=0
5985	226.786129	172.16.4.193	198.105.121.50	HTTP	423	GET /media/images/bitcoin.png HTTP/1.1
5986	226.786972	172.16.4.193	198.105.121.50	HTTP	404	GET /media/VanillaQR.min.js HTTP/1.1

Fig 6: Wireshark traffic to ransomware portal — victim GUID assigned, CAPTCHA solved, Bitcoin payment image loaded



Security vendors' analysis	Malicious	Phishing
ADMINUSLabs	Malicious	Phishing
BitDefender	Phishing	Malicious
Forcepoint ThreatSeeker	Malicious	Malware
G-Data	Phishing	Phishing
Lionic	Malicious	Phishing

Fig 7: VirusTotal — spotsbill.com 11/94 engines flagged malicious including Kaspersky, BitDefender, Fortinet



Server	IP	Port	Protocol
Server: 5.188.223.104 [spotsbill.com]	5.188.223.104	80	TCP
Server: 13.78.149.173 [cy4prdapp01-canary.cloudapp.net]	13.78.149.173	80	TCP
Server: 139.59.160.143 [retrotip.visionurbana.com.ve]	139.59.160.143	80	TCP
Server: 194.87.234.129 [tyu.benme.com]	194.87.234.129	80	TCP
Server: 198.105.121.50 [p27dokhpz2n7nvgr.1jw2lx.top]	198.105.121.50	80	TCP
Server: 204.79.197.200 [a-0001.a-msedge.net]	204.79.197.200	80	TCP
Server: 204.79.197.200 [a-0001.a-msedge.net]	204.79.197.200	80	TCP

Fig 8: NetworkMiner confirming all outgoing sessions from STEWIE-PC including spotsbill.com, tyu.benme.com, and p27dokhpz2n7nvgr.1jw2lx.top

Analysis & Interpretation

Attack flow, exfiltrated data, and false positive assessment

Files Downloaded via HTTP

- application/x-msdownload — 165kB ×2, 500kB
 - Windows executables = Cerber ransomware payload
- application/x-shockwave-flash — 16kB ×3
 - Flash exploit files triggering browser vuln
- Source: tyu.benme.com (194.87.234.129)

False Positive Assessment

- 15× RIG EK URI Struct — repeated = not coincidental
- Multiple independent rules confirm same event
- High confidence metadata on all critical rules
- spotsbill.com: 11/94 VT vendors — not a false positive
- 3 clean VT IPs: analyzed 4–7 yrs ago — IP reassignment

Data Exfiltrated About STEWIE-PC

- Browser type/version in GET params (biw=Vivaldi...)
- Browser flags and plugin data (br_fl=5844)
- Encoded system fingerprint (q= / oq= params)
- External IP discovered via msftncsi.com NCSI check
 - Windows auto-check reveals gateway public IP

MITRE ATT&CK Mapping

- T1189 — Drive-by Compromise (homeimprovement.com)
- T1203 — Exploitation for Client Execution (Flash/RIG EK)
- T1071 — App Layer Protocol (C2 over HTTP)
- T1486 — Data Encrypted for Impact (Cerber)
- TA0040 — Impact (ransomware objective)

Non-Technical Summary

Plain-language explanation for non-forensic readers

What happened?

A staff member's computer (STEWIE-PC) was infected with ransomware after visiting a legitimate-looking home improvement website that had secretly been hacked by attackers.

How did it happen?

The hacked website silently redirected the browser to a malicious server, which exploited a security flaw in Adobe Flash Player to automatically install the Cerber ransomware without the user clicking anything suspicious.

What did the ransomware do?

The ransomware encrypted the victim's files and displayed a payment page demanding Bitcoin cryptocurrency in exchange for the decryption key. It also sent information about the infected computer back to the attacker's servers.

Conclusions

Key findings proven through forensic analysis



STEWIE-PC (172.16.4.193) was infected with Cerber ransomware on 2017-01-27 via a drive-by download attack — confirmed by Suricata, Wireshark, NetworkMiner, and VirusTotal.



The infection vector was the RIG Exploit Kit delivered through a compromised WordPress site (homeimprovement.com) and an evil redirector (visionurbana.com.ve).



Malicious files downloaded via HTTP: Windows executables (165kB, 500kB) and Flash exploits (16kB) from tyu.benme.com — the C2 server and payload delivery mechanism.



The ransomware payment portal at p27dokhpz2n7nvgr.1jw2lx.top was fully loaded. A Bitcoin ransom address was displayed and the victim GUID EE7E-AD39-7D8C-080C-18BF was assigned.



Browser fingerprint data and system information were exfiltrated to the C2 server via encoded HTTP parameters. The external network IP was identified via Windows NCSI (msftncsi.com).



No lateral movement to other internal hosts was detected. The infection was contained to a single machine within the 172.16.4.0/24 network.



False positive probability is extremely low — multiple independent Suricata signatures corroborate the same events, confidence ratings are High, and VirusTotal confirms key IOCs.

Recommendations

Remediation steps tied to specific findings

1 Isolate and reimage STEWIE-PC

Finding: Cerber ransomware confirmed

Immediately isolate 172.16.4.193 from the network. Wipe and reimage — do not attempt decryption without validated backups.

3 Disable Adobe Flash Player

Finding: Flash exploit used by RIG EK

Flash is the primary attack vector. Disable or remove Flash Player across all endpoints immediately. It reached end-of-life in 2020.

5 Enable DNS filtering for .top TLD

Finding: Ransomware used .top domain

Alert on or block first-seen .top domain queries. The .top TLD is high-abuse and rarely legitimately required by end users.

2 Block malicious IPs and domains

Finding: Multiple C2 servers identified

Block 194.87.234.129, 198.105.121.50, 5.188.223.104, 139.59.160.143 and domains spotsbill.com, 1jw2lx.top, benme.com at perimeter firewall and DNS.

4 Block executable downloads over HTTP

Finding: Malware delivered unencrypted

Implement HTTP content inspection to block application/x-msdownload transfers. Enforce HTTPS-only browsing where possible.

6 Conduct enterprise IOC sweep

Finding: Cerber may have spread via other vectors

Search all endpoints for Cerber artifacts, encrypted files (.cerber extension), and registry persistence keys associated with RIG EK.

References

Tools, documentation, and authoritative sources

- Emerging Threats Ruleset (2025). ET EXPLOIT_KIT RIG EK URI Struct / ET MALWARE Ransomware/Cerber Onion Domain Lookup — Suricata IDS signatures.
- VirusTotal (2025). IP and domain analysis reports for 194.87.234.129, 139.59.160.143, 5.188.223.104, spotsbill.com, 1jw2lx.top, benme.com.
- MITRE ATT&CK Framework (2025). T1189: Drive-by Compromise; T1203: Exploitation for Client Execution; T1071: Application Layer Protocol; T1486: Data Encrypted for Impact; TA0040: Impact.
- Cisco Talos Intelligence Group. RIG Exploit Kit — threat summary, indicators, and C2 infrastructure. talosintelligence.com
- Wireshark Foundation (2025). Wireshark Display Filter Reference and HTTP Object Export documentation.
- BlockCypher Blockchain API (2025). Bitcoin address and transaction lookup — api.blockcypher.com.
- Security Onion Solutions (2025). Security Onion 2.4 documentation — Alerts, Hunt, and PCAP analysis workflow.
- NetworkMiner (Netresec, 2025). Network Forensic Analysis Tool — host enumeration, file extraction, OS fingerprinting.